



Serent 2026 Security Assessment

Powered by PortfolioView

Company:	Studio Designer
Assessment Completed:	June 26, 2026

Third-Party Acknowledgement and Affirmation of Non-Reliance of Report Contents

This document and its related contents are intended solely for the use of the intended recipient, as may be identified on the report, (the "Client"), as part of a service provided by Crosslake Technologies, LLC, or one of its Affiliates, (together "Crosslake"), and are governed by the terms of an underlying agreement between Crosslake Technologies and its Client. If You are not the Client or an Affiliate thereof, you are hereby notified that any dissemination, distribution, or copying of this information is strictly prohibited. References to "You" or "Your" include references to any of Your respective affiliates, general or limited partners, members, directors, officers, managers, employees, advisors, and counsel.

If You are not the Client as defined above, You expressly affirm and acknowledge that the contents of this report are provided to You for informational purposes only and are not intended to influence or guide You as a potential buyer or seller of any company or business analyzed herein. NO PARTY OTHER THAN THE CLIENT SHOULD RELY ON ANY INFORMATION CONTAINED IN THIS REPORT AS ACCURATE OR DEFINITIVE. FURTHERMORE, ALL RECIPIENTS ACKNOWLEDGE AND AGREE THAT ANY DECISIONS OR ACTIONS TAKEN AS A RESULT OF READING THIS REPORT WILL BE BASED SOLELY ON THEIR OWN INVESTIGATION AND EXPERTISE. EACH RECIPIENT AGREES TO CONDUCT THEIR OWN RESEARCH AND EXERCISE THEIR OWN PROFESSIONAL JUDGMENT, INDEPENDENT OF ANY INFORMATION PROVIDED HEREIN.

IF YOU HAVE A PREEXISTING EFFECTIVE AGREEMENT WITH CROSSLAKE GOVERNING YOUR RIGHTS WITH RESPECT TO THIS REPORT, THE TERMS OF SUCH AN AGREEMENT WILL PREVAIL.

This disclaimer affirms Your understanding that Crosslake Technologies does not sanction reliance on the content of this report by anyone other than the Client, and no other party should derive any expected benefit from it.



Assessment Overview

SCORE: 63

MEDIUM PROFICIENCY

LOW SCORING CATEGORIES	MEDIUM SCORING CATEGORIES	HIGH SCORING CATEGORIES
Recurring Hygiene39	Organization and Planning72 Technical and Tooling64 Secure Process73	

RESPONDENT INFORMATION

NAME: Russ McClelland ROLE: cto EMAIL: russ.mcclelland@studiodesigner.com

COMPANY PRODUCTS OR SERVICES

Saas for interior design firms.



Scoring Detail

COMPANY INFORMATION		N/A
1. Please list any data centers including address or upload a listing to the data room. Not Scored	Free-Form Response:	
2. Please list any cloud providers and regions in use. Not Scored	Free-Form Response: Cloud Provider: AWS Regions: US - East - 1 US - East - 2 US - West - 1 US - West - 2	
3. Please provide a list of all regions where the business operates. Not Scored	Free-Form Response: Regions: US - East - 1 US - East - 2	
4. Please provide a list and rationale for all applicable regulatory requirements for the organization. (e.g. California Privacy Rights Act or other U.S. state privacy laws, General Data Protection Regulation or other international privacy or security laws, New York Department of Financial Services Cybersecurity Regulation, Financial Industry Regulatory Authority (FINRA), Health Insurance Portability and Accountability Act, etc.) Not Scored	Free-Form Response: CPRA is applicable since our company is based in California and must adhere to local regulations. GDPR is applicable because we work internationally and must adhere to European regulations.	

5. Please provide a list of all applicable compliance certifications or security standards. (e.g. Payment Card Industry Data Security Standard, ISO, SOC, NIST, etc.). Please upload the latest two years of audit reports for applicable certifications or standards to the data room.

Not Scored

Free-Form Response:

We maintain internal security policies and controls aligned with recognized security frameworks; however, we do not currently hold formal certifications such as SOC 2, ISO 27001, PCI DSS, or NIST certification, and therefore do not have external audit reports for the past two years to provide.

6. Please provide a list of IT and Security service providers in use (e.g. Managed IT provider, Managed Security Service Provider).

Not Scored

Free-Form Response:

Microsoft 365 Microsoft Entra ID Microsoft Defender

7. Please provide a listing of key applications used by the company.

Not Scored

Free-Form Response:

AWS Atlassian Dhango Google Cloud Microsoft Namecheap Network Solutions Paylocity Payrix Plaid Rippling Scalegrid Stripe Zoom

SECURITY TOOLS

N/A

8. Please list the tool(s) in place to manage the network firewall(s).

Not Scored

Free-Form Response:

AWS WAF and Microsoft Defender

9. Please list the tool(s) in place to manage intrusion detection / prevention.

Not Scored

Free-Form Response:

Microsoft Defender and AWS Cloudwatch

10. Please list the tool(s) in place to manage remote access.

Not Scored

Free-Form Response:

Microsoft Defender for endpoint



11. Please list the tool(s) in place to manage multi-factor authentication.

Not Scored

Free-Form Response:

Microsoft Entra ID and AWS IAM

12. Please list the email security gateway tool(s) in place.

Not Scored

Free-Form Response:

Microsoft Defender

13. Please list the tool(s) in place to manage identity and access management.

Not Scored

Free-Form Response:

Microsoft Entra ID and AWS IAM

14. Please list the tool(s) in place to manage privileged access management

Not Scored

Free-Form Response:

Microsoft Entra ID and AWS IAM

15. Please list the tool(s) in place to manage endpoint device encryption,

Not Scored

Free-Form Response:

Microsoft Intune

16. Please list the tool(s) in place to manage endpoint protection (antivirus or EDR).

Not Scored

Free-Form Response:

Microsoft Defender for Endpoint

17. Please list the tool(s) in place to manage server disk / device encryption.

Not Scored

Free-Form Response:

Microsoft Intune

18. Please list the tool(s) in place to manage server protection (antivirus or EDR)

Not Scored

Free-Form Response:

AWS Cloudwatch

19. Please list the tool(s) in place to manage mobile device management of company-provided devices

Not Scored

Free-Form Response:

Microsoft Intune

20. Please list the tool(s) in place to manage mobile device management of personal user devices.

Not Scored

Free-Form Response:

N/A

21. Please list the tool(s) in place to manage endpoint patch management.

Not Scored

Free-Form Response:

Microsoft Intune

22. Please list the tool(s) in place to manage server and network patch management.

Not Scored

Free-Form Response:

AWS RDS

23. Please list the tool(s) in place to manage server and data backup.

Not Scored

Free-Form Response:

AWS flyway

24. Please list the tool(s) in place to manage network vulnerability management.

Not Scored

Free-Form Response:

Microsoft Defender and AWS Security Hub

25. Please list the tool(s) in place to manage application vulnerability management.

Not Scored

Free-Form Response:

Microsoft Defender Vulnerability Management

26. Please list the tool(s) in place to manage log management.

Not Scored

Free-Form Response:

AWS Cloud watch and Microsoft Defender/Microsoft Azure

27. Please list the tool(s) in place to manage security information and event management.

Not Scored

Free-Form Response:

Microsoft Defender and AWS Cloudwatch

28. Please list the vendor used for independent penetration testing.

Not Scored

Free-Form Response:

none

29. Please list the tool(s) in place to manage security training.

Not Scored

Free-Form Response:

Paylocity and HoxHunt

30. Please list the tool(s) in place to manage simulated phishing testing.

Not Scored

Free-Form Response:

HoxHunt

31. Please list any third-party managed security providers in use and the type of services performed.

Not Scored

Free-Form Response:

none

32. Please list the tool(s) in place for cloud security posture management.

Not Scored

Free-Form Response:

AWS Security Hub and AWS Cloud Watch

ORGANIZATION AND PLANNING

Score: 72

33. Which of the following are in place relating to the assignment of responsibilities for security?

4.4

RESPONDENT COMMENTS

All roles and responsibilities of IR team members are outlined in the IR policy for Studio Designer. These roles are defined but are only given in times of emergency. The principle for all Cybersecurity is the Analyst and CTO.

- ☐ Responsibilities have not been assigned for the security program.
- ☒ Named individual(s) are in place with ultimate responsibility and accountability for the security program.
- ☐ Which of the following security responsibilities have been assigned?
 - ☒ - overall roadmap and program oversight,
 - ☐ - program budget management or oversight,
 - ☒ - security policy and procedure management,
 - ☒ - cyber insurance accountability.
- ☐ None of the above or other. Please comment.
- ☒ *Required evidence:* The names of the individual(s) responsible for the security program. Please check when listed below or uploaded to the data room.
- ☒ *Required evidence:* A listing of the roles and responsibilities. Please check when listed below or uploaded to the data room.
-  Attachment: Analyst.png, Studio Designer Incident Response Policy.pdf, roles and responsibilities.png

34. Which of the following are in place to ensure data privacy accountability is assigned and a regular schedule of maintenance activities is performed to facilitate compliance through regulatory and company environment changes?

5.0

- ☒ The privacy policy is approved by the person with overall privacy responsibility.
- ☒ A review of applicability of regulatory changes is performed at least annually by the individual responsible for data privacy along with inside or outside counsel.
- ☒ A review and confirmation of data processing activities is performed.
- ☒ A review and approval of the company's privacy policy is performed.
- ☐ None of the above or alternative controls are in place. Please comment.
- ☒ *Required Evidence:* The name of the individual(s) ultimately accountable for privacy.
- ☒ *Required Evidence:* A copy of the company's privacy policy.
- ☒ *Required Evidence:* A schedule of activities performed to maintain the privacy program including owners.
-  Attachment: Privacyofficer.png, Privacy Policy _ Studio Designer.html, Privacy_Program_Policy.docx

35. Please indicate which of the following apply relating to cybersecurity insurance.

1.0

- ☒ The organization does not maintain cyber liability insurance.
- ☐ The organization maintains cybersecurity insurance.
- ☐ There are no policy exclusions or all policy exclusions have been addressed through appropriate risk mitigation measures. Please list any exclusions that have not been mitigated.
- ☐ Select all of the following that are covered in the policy.
- ☐ – data breach and privacy
- ☐ – network security
- ☐ – business interruption
- ☐ – cyber extortion
- ☐ – crisis management
- ☐ – support for public relations
- ☐ *Required evidence:* The company's current cyber insurance policy including any exclusions to the policy coverage. Please check when uploaded to the data room.
- ☐ *Required evidence:* Evidence that any resolvable exclusion criteria have been reviewed and are remediated. Please check when uploaded to the data room.

36. Which of the following are in place relating to the usage of generative AI in the organization?

5.0

RESPONDENT COMMENTS

The schedule is located in Section 4.

- ☒ An AI usage policy exists.
- ☐ Which of the following are included in the AI policy?
- ☒ - A statement specifying particular usage is explicitly allowed, and it is denied by default.
- ☒ - Explicit forbidding of uploading company confidential, internal use, or intellectual property (including code) to third-party services without explicit approval.
- ☒ The AI policy is signed off.
- ☒ Review of applicability of regulatory changes is performed at least annually by the individual responsible for AI along with inside or outside counsel.
- ☒ A periodic review and confirmation of GenAI usage activities is performed.
- ☐ An AI usage policy and practices are not in place or other, please comment.
- ☒ *Required evidence:* The names of the individual(s) accountable for generative AI governance. Please check when uploaded.
- ☒ *Required evidence:* A copy of the company's generative AI policy.
- ☒ *Required evidence:* A schedule of activities performed to maintain the AI policy compliance including owners.
-  Attachment: Alofficier.png, Studio Designer GenAI Policy.pdf

TECHNICAL AND TOOLING

Score: 64

37. Please indicate which of the following are in place to support backup management and testing.

5.0

RESPONDENT COMMENTS

We do not have a formal list for self-managed business-critical systems. But our two are AWS and Microsoft Business.

- ☒ We use only third-party systems and the providers manage backups.
 - ☒ Backups occur at an appropriate recurrence based on application or data criticality,
 - ☒ Backups are successfully completing,
 - ☒ Backups are encrypted at rest.
 - ☒ Backups are immutable and cannot be deleted, altered, or overwritten OR backups are stored in a secure location offsite that are inaccessible from the primary hosting location.
 - ☒ Full test restoration of backups is performed at least annually.
 - ☐ None of the above are in place or other, please comment.
 - ☒ *Required evidence:* A list of business-critical systems and applications that are self-managed (on-premise, data center, or public cloud). Please check when provided.
 - ☒ *Required evidence:* Backup schedule, configuration, and storage locations of backups for business-critical applications and systems, including immutability configuration. Please check when provided.
 - ☒ *Required evidence:* Historical backup job reports for business-critical applications and systems. Please check when provided.
-  Attachment: Assestsbackuphistory.png, backups.png

38. Which of the following are in place to support multi-factor authentication for critical applications?

4.0

RESPONDENT COMMENTS

We do not have any exceptions for MFA within our critical services. Dhango is sunset, and Google Cloud does not have a portal to show MFA.

- ☐ MFA is not in place for critical applications
 - ☐ A systems inventory is maintained that identifies critical systems.
 - ☒ MFA is enabled and enforced for critical systems via SSO/SAML or within the system itself.
 - ☒ MFA authentication is enforced for every administrative access attempt.
 - ☒ MFA authentication is required a minimum of every 72 hours for non-administrative access or upon "impossible travel".
 - ☒ There are no exceptions to use of MFA or exceptions are documented and approved by the individual designated to have ultimate security accountability.
 - ☒ *Required evidence:* A list of all back-office, corporate, and hosted systems with business-critical systems identified and the type of MFA enabled for regular users and administrative users (e.g. Netsuite, Salesforce, Amazon AWS). Please check when provided.
 - ☒ *Required evidence:* For systems with MFA enabled, provide the configuration and policy. Please check when provided.
 - ☒ *Required evidence:* For systems enabled with MFA, provide a list of users showing mode of authentication. Please check when provided.
 - ☒ *Required evidence:* Provide a list of users, role, or team-based exceptions to MFA including rationale and approval. Please check when provided.
-  Attachment: MFA_Netsuite.png, list of critical business systems.png, AWS_MFA_USERS.png

39. Which of the following are in place to support email security, filtering, and protection to enhance email security?

4.0

RESPONDENT COMMENTS

We do not make any exceptions to our email inspections therefore, there is no valuable evidence.

- ☐ We do not use an enhanced email scanning system or similar tools to inspect and filter email content and attachments.
 - ☒ We use an email gateway tool or similar enhanced level of scanning to inspect email content and attachments.
 - ☒ Email policy configurations are enforced across the organization.
 - ☐ Exceptions to email inspection are documented including the rationale and are approved by the individual designated to have ultimate security accountability.
 - ☒ Warning banners are implemented for external emails.
 - ☒ External email auto-forwarding of a users email account is disabled or alerts are sent if a email rule is created.
 - ☒ *Required evidence:* A screenshot or export of the phishing protection tooling console(s), policy configuration, and event logs. Please check when provided.
 - ☒ *Required evidence:* A list of users, role, or team-based exceptions to email inspection including rationale and approval. Please check when provided.
 - ☒ *Required evidence:* A historical report of blocked versus allowed email over the past 6 months. Please check when provided.
-  Attachment: blockedemails.png, Allowed Emails.csv, DefenderPhishing.png

40. Which of the following apply to the management of bring-your-own-device (BYOD) user devices?

5.0

RESPONDENT COMMENTS

Studio Designer doesnt manage a BYOB policy. Therefore, there is no evidence to provide for BYOB.

- ☒ The use personal (BYOD) devices is not permitted and mechanisms are in place to prevent connection to applications or networks.
- ☒ Tools are not utilized to manage BYOD user devices.
- ☐ A tool is in place to centrally manage personal devices that connect to company systems and networks.
- ☐ Encryption-at-rest is enforced for all devices in management.
- ☐ Strong passcodes are enforced to unlock devices.
- ☐ Software update and patching policies are enforced.
- ☐ Audit and event logging is enabled and are retained for at least 90 days.
- ☐ Exceptions to bring-your-own-device management are documented and approved by the individual designated to have ultimate security accountability.
- ☒ *Required evidence:* Screenshots or export of the end-user device management tooling console(s), policy configuration, and the central console event summary or audit log. Please check when provided.
- ☒ *Required evidence:* A list of devices enrolled in mobile device management. Please check when provided.
- ☒ *Required evidence:* Compliance report against the defined policy. Please check when provided.

41. Which of the following apply to endpoint protection for end-user devices?

5.0

- ☐ Endpoint protection is not in place.
- ☒ Endpoint protection management is centralized (even if across multiple vendors).
- ☒ Software and signature updates occur automatically and at least every 24 hours.
- ☒ There are no exceptions to endpoint protection for end-user devices OR exceptions to endpoint protection on servers are documented and approved by the individual designated to have ultimate security accountability and have risk-mitigating compensating controls in place
- ☐ None of the above or other, please comment.
- ☒ *Required evidence:* Screenshots or export of the endpoint protection tooling console(s). Please check when provided.
- ☒ *Required evidence:* Enrolled end-user device and server listing, Please check when provided.
- ☒ *Required evidence:* Event log. Please check when provided.
- ☒ *Required evidence:* A list of user endpoints. Please check when provided.
-  **Attachment:** endpoint protection console.png, Enrolled end-user devices.csv, endpoint log.png

42. Which of the following apply to endpoint protection for servers?

5.0

- ☐ Endpoint protection for servers is not in place.
- ☒ Endpoint protection management is centralized (even if across multiple vendors).
- ☒ Software and signature updates occur automatically and at least every 24 hours.
- ☒ There are no exceptions to endpoint protection for servers OR exceptions to endpoint protection on servers are documented and approved by the individual designated to have ultimate security accountability and have risk-mitigating compensating controls in place.
- ☐ None of the above or other, please comment.
- ☒ *Required evidence:* Screenshots or export of the endpoint protection tooling console(s) and software or signature update configuration. Please check when provided.
- ☒ *Required evidence:* Enrolled end-user device and server listing, Please check when provided.
- ☒ *Required evidence:* Event log. Please check when provided.
- ☒ *Required evidence:* A list servers. Please check when provided.
-  **Attachment:** Endpoint protection for servers.png, list of servers.png, event log.png, image (5).png

43. Which of the following are in place for user device configuration and patch management?

5.0

RESPONDENT COMMENTS

We do not have any exceptions to the endpoint protection. Therefore, there isnt any evidence to report.

- ☐ Configuration and patch management for end-user devices is not in place or is informally managed.
 - ☒ Configuration management is centralized for end-user devices (even if across multiple vendors).
 - ☒ A documented patch management policy exists and requires patching of critical and high severity patches for end-user devices within 30 days of release by the vendor.
 - ☒ Exceptions to endpoint configuration management are documented and approved by the individual designated to have ultimate security responsibility.
 - ☐ None of the above or other, please comment.
 - ☒ *Required evidence:* A screenshot or export of Configuration management tooling console(s), Enrolled endpoint and server listing, Examples of polic(ies) applied to endpoints including patching policy, Event log, and Patch report
 - ☒ *Required evidence:* Documented patch management policy. Please check when provided.
 - ☒ *Required evidence:* Documented build checklist or policy. Please check when provided.
 - ☒ *Required evidence:* A list of endpoint exceptions to the endpoint protection scope including rationale and approval, this includes endpoints and servers that are not patched to the latest versions. Please check when provided.
-  Attachment: StudioDesigner_PatchingVulnerabilityPolicy.pdf, Configuration Console.png, Enrolled Endpoints.png, patch report.png

44. Which of the following are in place for server configuration and patch management?

3.3

RESPONDENT COMMENTS

We do not have any exceptions to the endpoint protection. Therefore, there isnt any evidence to report.

- ☐ Configuration and patch management for servers is not in place or is informally managed.
 - ☒ Configuration management is centralized for servers (even if across multiple vendors).
 - ☒ A documented patch management policy exists and requires patching of critical and high severity patches for servers within 30 days of release by the vendor.
 - ☐ Exceptions to server configuration management are documented and approved by the individual designated to have ultimate security responsibility.
 - ☐ None of the above or other, please comment.
 - ☒ *Required evidence:* A screenshot or export of Configuration management tooling console(s), Enrolled server listing, Examples of polic(ies) applied to servers including patching policy, Event log, and Patch report
 - ☒ *Required evidence:* Documented patch management policy. Please check when provided.
 - ☒ *Required evidence:* A list of server exceptions to the endpoint protection scope including rationale and approval, this includes endpoints and servers that are not patched to the latest versions. Please check when provided.
-  Attachment: StudioDesigner_PatchingVulnerabilityPolicy.pdf, Patchmanagement_Update_Rings.png

45. Which of the following are in place for network device hardening and patch management.

1.0

- ☒ Processes to harden and patch network devices are not in place or are primarily informal.
- ☐ Only the SSH and HTTPS remote management protocols are used.
- ☐ Management and administrative interfaces are not exposed to the public Internet.
- ☐ Multi-factor authentication is required for administration.
- ☐ Default and root accounts are disabled or have strong, non-default passwords
- ☐ Network devices are patched in alignment with documented policy
- ☐ Exceptions to network hardening and patch management are documented and approved by the individual designated to have ultimate security responsibility.
- ☒ None of the above are in place or other, please comment.
- ☐ *Required evidence:* Network device asset list. Please check when provided.
- ☐ *Required evidence:* Network device patch level report. Please check when provided.
- ☐ *Required evidence:* Documented build checklist or process. Please check when provided.
- ☐ *Required evidence:* Network device patch management policy. Please check when provided.

46. Which of the following apply to the management of accounts with administrative privileges?

3.3

- ☒ Individuals with global administrator rights across systems are limited and appropriate.
- ☐ Administrator accounts are not shared.
- ☒ All administrator account activity is logged and monitored regularly.
- ☒ Individuals use different credentials to log in to accounts with global administration rights versus day-to-day accounts.
- ☒ Multi-factor authentication is enabled without exception.
- ☐ Administrators do not use service accounts for performing administrative actions.
- ☐ None of the above are in place or other, please comment.
- ☒ *Required evidence:* A list of all back-office, corporate, and hosted systems with business-critical systems identified (e.g. Active Directory, Office365, Netsuite, Salesforce, Amazon AWS).
- ☒ *Required evidence:* A screenshot or export of the list, titles, and employment status (FTE, contractor, MSP) of the Domain Administrators group for Active Directory, root accounts for cloud providers, and equivalent for back-office systems.
- ☒ *Required evidence:* Global account activity log.
-  **Attachment:** business critical systems.csv, Global Admins.png, Global Activity Log.png

47. Which of the following are in place to support network segregation?

5.0

- ☐ The network is not adequately segregated.
- ☒ Perimeter firewalls or security groups have "default deny" enabled and only allow explicitly approved traffic (public / private DMZ exists).
- ☒ Internal firewalls or security groups have "default deny" enabled and only allow explicitly approved traffic (public / private DMZ exists).
- ☐ None of the above or other, please comment.
- ☒ *Required evidence:* A screenshot or export of perimeter firewall(s) policies and configuration displaying ports and services open to the Internet. Please check when provided.
- ☒ *Required evidence:* A screenshot or export of internal firewall(s) policies and configuration. Please check when provided.
-  **Attachment:** internal firewall.png, AWSWAF.png, AWSserverprotection.png

48. Which of the following are in place to support secure remote access?

N/A

RESPONDENT COMMENTS

Remote Access is not permitted.

- ☒ Remote access is not permitted.
- ☐ IPSec-based VPN connections using key exchange are not used to support user remote access.
- ☐ SSL VPN access terminates after a period of 60 minutes of inactivity.
- ☐ Multi-factor authentication is required for all VPN or other remote access mechanisms.
- ☐ Email is not used to provide the multi-factor authentication token.
- ☐ Access is granted using role or group-based permissions.
- ☐ Audit logs of user connectivity is kept for at least 90 days.
- ☐ Block listing of embargoed countries and non-primary workforce locations via geo-restrictions is enabled.
- ☐ Exceptions to remote access requirements are documented and approved by the individual designated to have ultimate security responsibility,
- ☒ None of the above or other, please comment.
- ☐ *Required evidence:* Remote access tooling configuration including a screenshot or export of user's allowed to access the environment remotely, multi-factor authentication enforcement, encryption algorithms, audit logging, geo-restriction configuration, and timeout.
- ☐ *Required evidence:* Endpoint checks for systems (up to date patching, AV running, etc.). Please check when provided.
- ☐ *Required evidence:* A screenshot or export of the audit log including user connections. Please check when provided.

49. Which of the following are in place to support monitoring, alerting, and timely response to security events?

3.3

- ☐ Monitoring processes are not in place or are informal.
- ☐ An outsourced managed services provider is responsible for monitoring alerts, events, and audit logs.
- ☒ A call tree is documented specifying the order in which key stakeholders in the organization are notified, when, and how.
- ☒ Runbooks and tooling include the ability for the security operations center or similar team to take immediate action to quarantine or isolate infections.
- ☐ None of the above or other, please comment.
- ☒ *Required evidence:* Call tree for alerting that requires attention. Please check when provided.
- ☒ *Required evidence:* A screenshot or export of a reporting dashboard showing last 3 months of log activity. Please check when provided.
- ☒ *Required evidence:* Documented processes for response: SLAs, checklists, and runbooks. Please check when provided.
- ☒ *Required evidence:* Example tickets for response. Please check when provided.
-  Attachment: IR FlowCharts - IR Plan.pdf, event log.png, ticketexample.png, call tree.png

50. Which of the following are in place to support remote tooling hardening?

1.0

- ☒ Individuals with administrative rights access to tooling is limited and appropriate.
- ☐ Administrator accounts are not shared.
- ☐ Administrative access requires multifactor authentication on every login.
- ☐ All administrative activity and support sessions are logged and stored for 1 year.
- ☐ Remote support sessions automatically log off or require reconnection after 30 minutes.
- ☐ Initiating remote support sessions requires one of: One-time passcode or pin; Certificate-based authentication; or Biometric verification.
- ☒ None of the above or other, please comment.
- ☐ *Required evidence:* A list of all remote support tools used internally or by third-parties (MSP) including but not limited to: TeamViewer, Splashtop, GoToMyPC, AnyDesk, RemotePC, Zoho Assist, VNC Connect.
- ☐ *Required evidence:* Remote support tooling configuration including logging configuration.
- ☐ *Required evidence:* A list of employees and contractors and access levels for each of the remote support tools.

51. Which of the following are in place to support encryption at rest of end user devices?

5.0

- ☒ Encryption-at-rest is deployed on all hard disks on all end-user devices.
 - ☒ Centralized, industry recognized tooling is used to manage encryption (even if multiple vendors).
 - ☒ Deprecated encryption and hashing algorithms, including the below, are not utilized for the encryption process. - DES - 3DES - RC4 - MD5 - SHA1
 - ☒ Recovery keys are only accessible by authorized personnel.
 - ☐ None of the above or other, please comment.
 - ☒ *Required evidence:* A screenshot or export of: - Encryption at rest tooling console(s) - Enrolled end-user device listing.
 - ☒ *Required evidence:* End-user device asset list including laptops, desktops, tablets, and mobile devices.
 - ☒ *Required evidence:* Recovery key access list.
-  Attachment: DeviceEncryptionV3_d9eff524-bc2f-4008-b722-336a73c30e91.zip, DevicesWithInventory_16f14b54-2994-453c-bf6f-417f100504f3.zip, recovery key access list.png

52. Which of the following are in place to centrally manage public cloud account structure?

2.5

- ☒ Accounts are consolidated in the multi-account structure without exception.
 - ☐ Accounts have a designated and documented owner and purpose.
 - ☐ None of the above are in place or other, please comment.
 - ☒ *Required evidence:* Inventory of cloud accounts including owner, purpose, and whether they are centrally managed or not.
 - ☐ *Required evidence:* A screenshot or export of organizational hierarchy or structure from cloud console.
-  Attachment: cloudaccounts.png

53. Which of the following are in place to support network access control?

5.0

- ☒ Unauthorized and unknown devices are, by default, not allowed on company networks.
- ☒ Certificates or user authentication are used to identify and authenticate known devices.
- ☒ Real-time visibility of the assets on networks is available.
- ☒ Stakeholders are notified immediately when an unauthorized device attempts to connect to company networks (excluding guest networks).
- ☐ None of the above or other, please comment.
- ☒ *Required evidence:* A screenshot or export of network access control tooling configuration including policy enforcement or checks performed prior to allowing an asset on the network.
- ☒ *Required evidence:* A screenshot or export of asset tracking of the network(s) in real-time.

 Attachment: network access control dashboard.png, Asset Tracking.png

54. Please indicate which of the following are in place to secure LLM training data.

1.0

RESPONDENT COMMENTS

Studio Designer does not train LLMs or maintain any LLMS.

-  ☒ Security training is not in place or is performed informally.
- ☐ All sources of training data are licensed for use and fit for purpose.
- ☐ The access control list aligns to the least privilege principle based on roles or groups.
- ☐ Training data is encrypted at rest at the repository, disk, or data level using AES256 or another modern algorithm.
- ☐ Encryption keys are managed by authorized personnel only.
- ☐ None of the above or other, please comment.
- ☐ *Required evidence:* An inventory of training data including the source of the data, license for use, and where it is stored. Please check when provided.
- ☐ *Required evidence:* Access control lists for training data repositories including name and role. Please check when provided.
- ☐ *Required evidence:* Access control lists for training data repositories including name and role. Please check when provided.

55. Please indicate which of the following are in place to secure the LLM environment.

1.0

RESPONDENT COMMENTS

Studio Designer does not train LLMs.

-  ☒ Security training is not in place or is performed informally.
- ☐ Authentication is centralized across accounts.
- ☐ Strong password policy is in place that requires twelve characters.
- ☐ Multifactor authentication is enforced and re-authentication is enabled.
- ☐ Group or role structures are in place to grant permissions.
- ☐ Administrative accounts, groups, or roles are separate from day-to-day use.
- ☐ Least privilege and role-based access principles are enforced via policies.
- ☐ Filtering devices (e.g. firewall, software firewall, WAF, etc.) exist between network housing model file and development, staging, and other environments.
- ☐ Access to the environment is "default deny".
- ☐ Model files are immutable (read-only) and not directly accessible.
- ☐ None of the above or other, please comment.
- ☐ *Required evidence:* A screenshot or export of authentication and authorization requirements for model or model environment are accessed for inference, training, or management. Please check when provided.
- ☐ *Required evidence:* A screenshot or export of firewall(s) or system policies and configuration displaying how models or the model environment are accessed for inference, training, or management. Please check when provided.

56. Please indicate which of the following are in place to ensure base model integrity.

1.0

RESPONDENT COMMENTS

Studio Designer does not manage and LLMs.

- ☒ Base models are not managed or are informally managed.
- ☐ All base model signature and sources are verified prior to use.
- ☐ Validity and bias testing of the base model is performed prior to deployment.
- ☐ Security testing of the base model is performed prior to deployment.
- ☐ None of the above or other, please comment.
- ☐ *Required evidence:* Records of security and validity testing.

57. AI/LLM Visibility

3.6

RESPONDENT COMMENTS

All approved AI have a metric dashboard that shows all usage.

- ☒ A documented inventory of approved generative AI tools and associated business use cases is maintained and reviewed at least annually.
- ☒ Technical controls are implemented to detect or restrict unauthorized ("shadow") use of generative AI tools.
- ☒ GenAI use cases are risk-classified based on data sensitivity and business impact
- ☒ An approval and risk review process exists for onboarding new generative AI tools or use cases.
- ☒ Logging and monitoring mechanisms provide visibility into enterprise-approved GenAI usage
- ☐ Sensitive data monitoring controls (e.g., DLP, CASB, proxy controls) are configured to address external AI platforms.
- ☐ None of these are in place (please comment)

SECURE PROCESS

Score: 73

58. Please indicate which of the following procedures and protection mechanisms are in place to protect high risk transactions.

5.0

- ☒ A procedure for high-risk transactions is in place and requires known-voice verification or the equivalent for inbound and outbound money exchange processes including: Payroll, bank account changes, changes to payable account bank information, and changes to receivable account bank information
 - ☒ Multi-factor authentication is required for login to all bank accounts across the enterprise.
 - ☒ Ad-hoc wire transfers need multi-stage and multi-party approval.
 - ☒ Invoices state the company will never ask you to change remittance information via email.
 - ☐ None of the above are in place or other, please comment.
 - ☒ *Required evidence:* Procedure documenting the requirements for high-risk transactions including, payroll, bank account changes, changes to payable account bank information, and changes to receivable account bank information. Please check when provided.
 - ☒ *Required evidence:* A screenshot or export of multi-factor authentication configuration for bank account(s) (redact out non-applicable information). Please check when provided.
 - ☒ *Required evidence:* A copy of example invoices. Please check when provided.
- Attachment: SVBMFA.png, Studio Payment Processing Policy.docx, example invoice .png

59. Which of the following are in place for high risk transaction policy, accountability, and training?

2.0

- ☒ A policy is in place for high risk transactions that contains the statement "No changes to financial systems shall occur through email exchanges or without known-voice verification. These systems include but may not be limited to payroll, vendor payables, and bank accounts."
 - ☒ The policy has been updated within the past year.
 - ☐ The policy states that all employees and contractors with access to financial systems are required to sign off on the policy at onboarding and prior to being granted access to any financial system.
 - ☐ Is signed off on by the Chief Financial Officer of the company.
 - ☐ All employees and contractors with access to or ability to change financial systems have digitally or physically signed off on their responsibility relative to the policy during onboarding and at least annually thereafter.
 - ☐ None of the above or other, please comment below.
 - ☒ *Required evidence:* Documentation showing the policy around high risk transaction systems including payroll and bank account changes.
 - ☒ *Required evidence:* A listing of employees and contractors with access to or ability to request changes to financial systems (e.g. - payroll systems, vendor payables, and bank accounts).
 - ☒ A screenshot or export of a training tool or copies of paperwork showing that members of the above list have signed off on the company policy.
-  Attachment: Studio Payment Processing Policy.docx, Studio Accounts Payable Policy.docx, Example Payment .png

60. Please indicate which of the following are in place to support preparedness to respond to a security incident, have a documented plan, and test that plan at least annually.

3.1

RESPONDENT COMMENTS

A tabletop has now been done for the IR plan this year, but is planned.

- ☐ We do not have an incident response plan or supporting procedures.
 - ☒ Documented incident management and response plan and procedure(s) exist.
 - ☐ Which of the following are documented in the plan and procedures? (Select all that apply)
 - ☒ - roles and responsibilities
 - ☒ - external communication strategy
 - ☐ - internal communication strategy including notification procedures to the PE firm at the time of incident
 - ☒ - communication templates
 - ☐ The test has been facilitated and documented by a third-party.
 - ☒ The incident response plan has been tested within the past 12 months.
 - ☒ The test includes ransomware and business email compromise scenarios.
 - ☒ The test Involved all stakeholders – Exec leadership, Security, IT, HR, Counsel, client-facing roles, PE firm leadership
 - ☐ The test includes documented lessons learned and improvements to be made with action owners.
 - ☐ AI-related incident scenarios are tested through tabletop or simulation exercises
 -  ☐ The incident response plan explicitly includes AI-related incident scenarios
 - ☐ AI-related incident scenarios are tested through tabletop or simulation exercises
 - ☐ None of the above or other, please comment.
 - ☒ *Required evidence:* Provide a copy of your incident response plan. Please check when provided.
 - ☐ *Required evidence:* Provide a third-party or internal report or written overview describing the last test of the plan (tabletop being sufficient).
-  Attachment: Studio Designer Incident Response Policy.pdf

61. Please indicate which of the following are in place so support preparedness to respond to a security incident or disaster, recover critical systems and data, have a backup management program in place with documented recovery procedure(s), and test that plan at least annually.

3.8

- ☐ We do not maintain any systems, all systems are cloud-based or outsourced.
- ☐ We do not have processes in place to adequately respond to security events or disasters and recover systems.
- ☒ Technical recovery procedures or runbooks exist for critical systems.
- ☒ Technical recovery procedures or runbooks are adequately up-to-date.
- ☒ An offline copy of the runbooks has been saved in a secure location.
- ☐ Which of the following are documented in the procedures / runbooks? (Select all that apply)
- ☒ - a listing of key stakeholders including IT, networking, security, and critical third-party or vendor contacts
- ☐ - the locations of data backups if applicable
- ☐ - the locations of server / infrastructure backups
- ☒ - prescriptive instructions on how to rebuild network and server environment including system dependencies, recovery ordering, validation steps, and system requirements.
- ☒ An offline copy of the runbooks has been saved in a secure location (e.g. with Private Equity)
- ☐ None of the above are in place or other, please comment.
- ☒ *Required evidence:* A copy of technical recovery runbooks for critical systems and applications.
-  Attachment: AWS Regional Failure Disaster Recovery Playbook - Overview.pdf

62. Please indicate which of the following are in place to support associate onboarding and offboarding processes.

5.0

- ☐ Onboarding and offboarding procedures are not in place or are informal.
- ☒ Documented onboarding and offboarding procedures exist.
- ☒ Separation of duties is in place between those requesting the onboarding or offboarding and those approving access to systems.
- ☒ A checklist of critical systems access is validated during onboarding and offboarding.
- ☒ Procedures are in place to obtain a return of assets during offboarding.
- ☒ Offboarding of access to systems occurs within 24 hours of request and within 4 hours for IT administrative users.
- ☒ Personal devices are wiped of company data as part of the process or checklist for offboarding.
- ☐ None of the above or other, please comment.
- ☒ *Required evidence:* Provide a copy of your onboarding and offboarding process. Please check when provided.
- ☒ *Required evidence:* A screenshot or export example of onboarding and offboarding requests (tickets) for new and terminated employees, contractors, or vendors. Please check when provided.
-  Attachment: ONBOARDING_PROCESS.png, OFFBOARDING_PROCESS.png, OFFBOARDING_TICKET.png

63. Secure agentic engineering review

3.6

- ☒ Human review is mandatory for AI-generated code prior to merge or deployment
- ☒ AI-generated code is subject to secure coding standards and automated security testing prior to release
- ☒ AI-generated changes cannot bypass standard peer review and change management processes
- ☒ Developers are required to disclose or tag AI-assisted code contributions
- ☒ Reviewers are trained to identify AI-specific risks (e.g., hallucinated logic, insecure defaults, licensing concerns)
- ☐ Licensing and intellectual property risks of AI-generated code are evaluated prior to release
- ☐ None of these are in place (please comment)

RECURRING HYGIENE

Score: 39

64. Which of the following are in place to ensure automated or manual security testing of code occurs prior to release of changes. Issues identified by security testing are resolved in a timely manner?

5.0

- ☒ All code and dependencies for client-facing software is manually QA tested or scanned via automation for security issues.
- ☒ Documented software development process or policy exists and requires resolution of critical and high severity security issues within 30 days of identification.
- ☒ Critical or high severity vulnerabilities have been reviewed, triaged, and have been resolved or will be resolved within the next 30 days.
- ☐ None of the above or other, please comment.
- ☒ *Required evidence:* A screenshot or export of tooling utilized for security testing such as SAST, DAST, dependency scanning, or automated QA.
- ☒ *Required evidence:* A screenshot or export of quality assurance tests that are specific to security.
- ☒ *Required evidence:* Documented software development lifecycle process or policy .
-  Attachment: SAST_Screenshot.png, SDLC_POLICY.png, QA_Test.png

65. Please indicate which of the following are in place to support security and AI training.

3.1

RESPONDENT COMMENTS

Employees are currently not required to sign off on the AI/Security Policy. A mandatory training with the Cybersecurity Analyst is required upon hiring.

- ☐ Security training is not in place or is performed informally.
- ☐ AI training is not in place or is performed informally.
- ☐ The training policy requires training during onboarding and at least annually thereafter.
- ☐ A record of attendance is generated for those participating in the training.
- ☒ Required training includes security best practices.
- ☒ Required training includes phishing, smishing, and vishing.
- ☒ Required training includes social engineering.
- ☒ Required training includes business email compromise.
- ☒ Required training includes generative AI overview.
- ☒ Required training includes the responsible use of GenAI.
- ☒ Required training includes risks of GenAI.
- ☒ Required training includes company-specific GenAI policy.
- ☒ All employees and relevant contractors are required to, and have signed off on the company's Generative AI policy.
- ☒ All employees and relevant contractors are required to, and have signed off on the company's Security or Acceptable Use policy.
- ☐ None of the above or other, please comment.
- ☒ *Required evidence:* A screenshot or export of centralized training or learning management system if applicable. Please check when provided.
- ☒ *Required evidence:* A screenshot or export of title and table of contents of required training module(s) or content.
- ☒ *Required evidence:* A screenshot or export of policy or recurrence of training.
- ☒ *Required evidence:* A screenshot or export of most recent sign-off of employees on the AI policy.
- ☒ *Required evidence:* A screenshot or export of most recent sign-off of employees on the security policy.
- ☒ *Required evidence:* If applicable, screenshot of previously completed training campaigns.
-  Attachment: Centralized training.png, Required_Training_Catalog.png, Required_Training_Schedule.png, 2026 Compliance Training Results (1).xlsx

66. Which of the following are in place for third-party network penetration testing?

1.0

RESPONDENT COMMENTS

All penetration testing is handled internally. We are working with a company this year to complete a third-party pentest.

- ☐ Penetration is performed by a qualified third-party against all public-facing infrastructure and includes manual testing and verification of issues.
- ☐ The scope of the testing is non-credentialed external network testing and includes: - All domains of the company and its acquisitions - DNS enumeration (reconnaissance) of domains in scope - IP addresses or hostnames of all sites not tied to DNS including offices, manufacturing locations, data centers, and cloud infrastructure.
- ☐ The penetration testing report is within the last 12 months.
- ☐ Critical and high severity vulnerabilities identified in the report have been remediated and third-party re-test has taken place to confirm fixes.
- ☒ **None of the above or other, please comment.**
- ☐ *Required evidence:* An export of the domains, IP addresses, and hostnames being scanned on a recurring basis.
- ☐ *Required evidence:* Inventory of acquisitions made over the past 5 years.
- ☐ *Required evidence:* The organization's most recent third-party external network penetration report if available.

67. Which of the following are in place for third-party application penetration testing?

1.0

RESPONDENT COMMENTS

Studio Designer has not had a Third-Party Pentest.

- ☐ An application vulnerability management policy is in place.
- ☐ The application vulnerability management policy requires a credentialed third-party penetration testing of developed and hosted SaaS software at least annually.
- ☐ Critical or high severity findings in the tests have been reviewed, triaged, and have been resolved or will be resolved within 60 days of identification.
- ☒ **None of the above or other, please comment.**
- ☐ *Required evidence:* Please provide a copy of your vulnerability management policy and process.
- ☐ *Required evidence:* If applicable, provide historical copies of detailed non-credentialed application penetration testing reports including scope and findings.
- ☐ *Required evidence:* If applicable, provide historical copies of detailed credentialed application penetration testing reports including scope and findings.
- ☐ *Required evidence:** If applicable, provide copies of remediation plans and progress against the findings reported in penetration tests.

68. Please indicate which of the following apply to the contracting and onboarding of vendors that have access to company systems or data.

1.0

- ☐ We do not engage vendors that have access to company systems or data
-  ☒ Vendor onboarding processes are informal or undocumented.
- ☐ A documented process for onboarding new vendors or renewing existing vendors is in place.
- ☐ Vendor access provisioning is performed in alignment with a documented process.
- ☐ Which of the following acceptable contractual security criteria are documented? (Check all that apply)
 - ☒ – incident notification period,
 - ☒ – audit rights of the company
 - ☒ – service level agreements,
 - ☒ – subcontractor security
 - ☒ – data retention and destruction,
 - ☒ – confidentiality
 - ☒ – data breach liability
- ☒ *Required evidence:* Documentation of the process for onboarding new vendors or renewing existing vendors.
- ☒ *Required evidence:* A list of active IT vendors, service providers, or contractors with access to company systems or data.
- ☒ *Required evidence:* A screenshot or export of tickets for onboarding the above vendors, service providers, and contractors.
-  Attachment: Vendorlist.png, Vendor_ticket.png, Studio Designer Contractor Onboarding Policy.pdf

VALIDATION CALL

N/A

69. Please provide several one-hour times starting after one week that you are available to meet to discuss questions the Crosslake practitioner may have about the assessment results.

Not Scored

Free-Form Response:

06/ 29 - 4:00 PM 6/30 - 4:00 PM 7/1 - 4:00 PM 7/2 - 4:00 PM 7/6 - 4:00 PM
7/7 - 4:00 PM 7/8 - 4:00 PM